PROJETO APLICADO · EIXOS 1, 2 E 3 · GCP ALWAYS FREE

Infraestrutura GCP endurecida e app Next.js com deploy por release

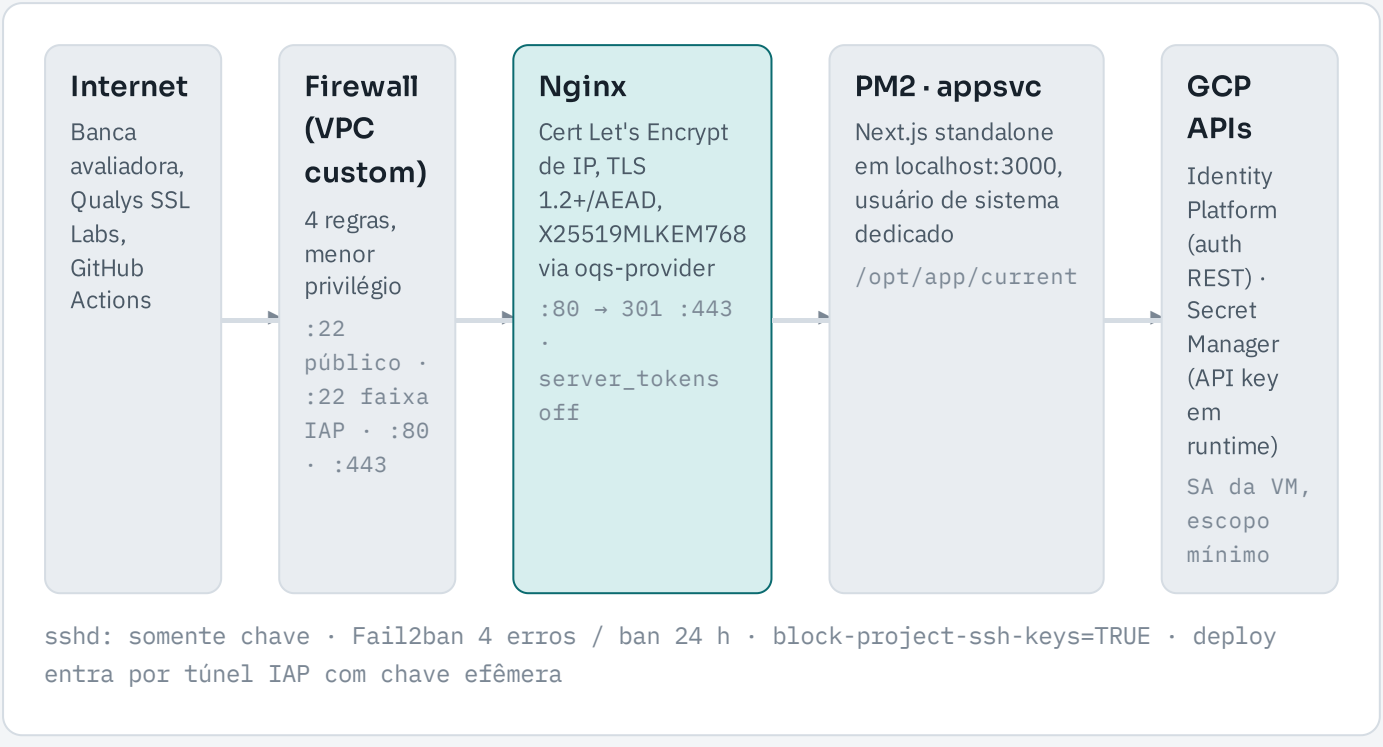
Uma `e2-micro` Ubuntu 24.04 provisionada por Terraform e um startup script idempotente, Nginx com TLS pós-quântico, aplicação Next.js 16 com autenticação server-side, e um pipeline GitHub Actions keyless que só toca a VM quando uma release semver é cortada.

● **app-vm** RUNNING IP **35.211.63.76** HTTPS **200** · HTTP **301**

web **v1.1.0** · Next **16.3.4** · React **19.2.8** snapshot 2026-09-19

Fluxo de requisição

docs/architecture.md



sshd: somente chave · Fail2ban 4 erros / ban 24 h · block-project-ssh-keys=TRUE · deploy entra por túnel IAP com chave efêmera

Os três eixos do prd.md

o que a banca avalia, e onde está

EIXO 1

Infraestrutura

- ✓ **Ubuntu 24.04** Shielded VM, `e2-micro`, tudo no free tier
- ✓ **Nginx** como web server e reverse proxy
- ✓ **IP público** sem domínio; estático só enquanto a VM está ligada
- ✓ **SSH só por chave**, `PasswordAuthentication no`
- ✓ **Fail2ban** jail sshd, 4 tentativas, 24 h de ban
- ✓ **Certbot (snap)** com certificado de IP e renovação automática
- ✓ **HTTP → HTTPS** 301 obrigatório
- ✓ **SSL Labs nota A** + PQC ativo (`X25519MLKEM768`)

EIXO 2

Repositório

- ✓ **Repo público** no GitHub, versionado com Conventional Commits
- ✓ **Nada de segredo commitado**: `terraform.tfvars` , `backend.hcl` gitignorados
- ✓ **Project ID nunca hardcoded**; bucket de state via `-backend-config`
- ✓ **Sem chave SSH** em secrets do GitHub; WIF keyless
- ✓ **CI guardrail** falha o PR se a deploy SA ganhar role de projeto

EIXO 3

Aplicação

- ✓ **Login**, página interna protegida, **Logout** funcional
- ✓ **Next.js 16** App Router, TypeScript, Vitest
- ✓ **Sessão em cookie HttpOnly** via Identity Platform, verificada no servidor
- ✓ **CSRF** same-origin + **CSP com nonce**
- ✓ **Formulários HTML puros**, sem JS no cliente; redirects 303
- ✓ **OWASP Top 10:2025**: 9 de 10 mitigadas em código (mínimo exigido: 3)

Pipeline: do push à VM

.github/workflows/release.yml → deploy.yml

01 **`git push origin main`**

Dispara `release.yml` imediatamente. `ci.yml` já rodou lint, typecheck e testes no PR.

02 **release-please abre ou atualiza o PR `chore(main): release X.Y.Z`**

Bump semver por Conventional Commits (`feat` → minor, `fix` → patch) e `web/CHANGELOG.md`. Nunca editado à mão.

03 **Merge do PR de release = tag `vX.Y.Z` + GitHub Release**

Só aqui `deploy.yml` é chamado. Um push comum não chega à VM.

04 **`npm ci`, testes, `next build` standalone no runner**

Nunca na VM (1 GB RAM). Raiz do bundle é `.next/standalone/web`, static e public re-adicionados.

05 **Auth GCP keyless por Workload Identity Federation**

Deploy SA sem role de projeto: só `compute.instanceAdmin.v1` na instância, `iap.tunnelResourceAccessor` e o custom role read-only `deployVmOperator`.

06 **scp/ssh por túnel IAP, chave efêmera**

`/opt/app/releases/<sha>` → `current`; `pm2 delete` + `pm2 start` como `appsvc`. `.env.production` só com `NODE_ENV`, `PORT`, `GOOGLE_CLOUD_PROJECT`.

07 **Health check: poll `https://<ip>/` até HTTP 200**

Até 2 minutos. Falha do poll = job vermelho.

> O gate por release é deliberado: cada deploy corresponde a uma tag auditável (OWASP *Software and Data Integrity Failures*). Redeploy sem cortar release: `workflow_dispatch` no workflow **Deploy**.

OWASP Top 10:2025 na aplicação

README.md · mecanismo e arquivo por categoria

Identification & Authentication Failures — mitigada

5 falhas de login por IP bloqueiam 60 s (`lib/security/rate-limit.ts`); erros genéricos sem enumeração; senha ≥ 12 chars com classes obrigatórias.

Broken Access Control — mitigada

Sessão verificada no servidor em toda rota protegida; CSRF por comparação de `Origin` em `proxy.ts` (depende de `X-Forwarded-Proto` do Nginx).

Security Misconfiguration — mitigada

Headers OWASP completos, CSP com nonce, `poweredByHeader: false`, `server_tokens off`.

Cryptographic Failures — mitigada

Cookie de sessão `HttpOnly; Secure; SameSite`; API key só no Secret Manager, lida em runtime pela SA da VM (`lib/gcp/secret.ts`).

Injection — mitigada

Sem banco de dados, sem superfície de query; entrada verificada por tipo antes de qualquer uso.

Insecure Design — mitigada

Senha validada antes de chamada externa; não enumeração sistemática; fail-closed em erro de rede, parsing ou credencial ausente.

Software & Data Integrity Failures — mitigada

Deploy só por release; health check pós-deploy; todo `JSON.parse` protegido.

Software Supply Chain Failures — parcial

`package-lock.json` versionado, `npm ci` no CI. Lacuna documentada: sem Dependabot/Renovate nem `npm audit` no pipeline.

Startup script: estágios idempotentes

infra/scripts/startup.sh.tpl · roda em todo boot, cada estágio com guard próprio

0	**Auto-reparo**: se o provider PQC quebrou o `openssl.cnf` (`nginx -t` falha), reverte e restaura SSH/Nginx antes de tudo
1	**Pacotes base** nginx, fail2ban, snapd, curl, ca-certificates
1b	**Node.js 24 LTS** via NodeSource (apt do 24.04 traz Node 18)
2	**SSH hardening** `PasswordAuthentication no` ; reload em `ssh.service` , não `sshd`
3	**Fail2ban** jail sshd, 4 tentativas, ban 24 h
4	**Certbot via snap** (versão ≥ 5.4 com suporte a certificado de IP)
5	**Site HTTP base** para o desafio ACME HTTP-01 · **5b** `server_tokens off`
6	**Certificado de IP** da Let's Encrypt
7	**Server block HTTPS** com política TLS 1.2+/AEAD dentro do bloco (override do `nginx.conf` stock) + redirect 301
8	**Timer de renovação** do Certbot · **8b** ativa `X25519MLKEM768` via `oqsprovider.so` baixado do bucket `vm-assets` ; `systemctl restart nginx` , nunca `reload`
9	**Usuário appsvc** + PM2 + unit systemd `pm2-appsvc`
10	**/opt/app** + `ecosystem.config.js` reescrito em todo boot + reverse proxy com `X-Forwarded-*` ; guard `tls-policy vN` reescreve vhosts antigos

Layout do repositório

```
web/                Next.js 16 · route.ts + handler.ts testados
infra/bootstrap/    state bucket + billing budget (local state, nunca destruído)
infra/              VPC, firewall, compute, Identity Platform, WIF, Secret Manager
infra/scripts/      startup.sh.tpl + ecosystem.config.js
ops/                vm-start.sh / vm-stop.sh
.github/workflows/  ci · release · deploy · build-oqsprovider
docs/               arquitetura, deploy, operação, segurança, free tier, troublesho
prd.md              requisitos da disciplina
```

Operação e custo zero

ligar	`./ops/vm-start.sh` reserva IP estático, anexa, inicia
desligar	`./ops/vm-stop.sh` para a instância, libera o IP
por quê	**IP reservado só cobra quando não está anexado a VM ligada.** Terraform declara IP efêmero; reserva vive só na janela em que a VM está de pé.
drift	`terraform apply` com a VM ligada troca o IP de volta para efêmero. Preferir `vm-stop.sh` antes.
nunca	`gcloud compute instances start/stop` direto, nem `addresses create/delete` à mão

Lições que só o deploy real ensinou

1. **Unit do SSH é `ssh.service`** no Ubuntu 24.04; `reload sshd` mata o script inteiro sob `set -euo pipefail`.
2. **Path do cert embute o IP**; o guard do vhost HTTPS precisa comparar o IP embutido com o atual, não só checar se o arquivo existe.
3. **`ecosystem.config.js` reescrito sempre**; guard `[ ! -f ]` deixou uma cópia antiga crash-loopando com `ENOENT /opt/app/package.json`.
4. **Standalone aninhado em `.next/standalone/web/`** por causa do workspace; static e public não vêm junto.
5. **Sem `X-Forwarded-Proto: https`** todo `POST /api/auth/*` dava 403 na comparação de origem.
6. **`reload` não ativa provider OpenSSL novo**; workers herdam estado do master. Só `restart`.
7. **liboqs não compila na e2-micro** em tempo razoável; provider vem de um runner `ubuntu-24.04` e do bucket privado.
8. **`ssl_protocols` dentro do server block**, senão TLS 1.0/1.1 do `nginx.conf` stock capa a nota em B.

---

fonte: README.md, prd.md, docs/, CLAUDE.md · estado da VM verificado em 2026-09-19